

**44. SEGURIDAD EN ENTORNOS
DE RED PRIVADOS.
MECANISMOS DE PROTECCIÓN
DE LA CONFIDENCIALIDAD.
SERVICIOS DE DIRECTORIO.
GESTIÓN DE IDENTIDADES.
SINGLE SIGN-ON. TIPOS DE
CONECTIVIDAD. ACCESO
REMOTO. VPN.**

Tema 44. Seguridad en entornos de red privados. Mecanismos de protección de la confidencialidad. Servicios de directorio. Gestión de identidades. Single sign-on. Tipos de conectividad. Acceso remoto. VPN.

INDICE

<u>1 SEGURIDAD EN ENTORNOS DE RED PRIVADOS. MECANISMOS DE PROTECCIÓN DE LA CONFIDENCIALIDAD.....</u>	<u>2</u>
<u>2 SERVICIOS DE DIRECTORIO.....</u>	<u>5</u>
<u>2.1 LDAP.....</u>	<u>7</u>
2.1.1 El modelo de información.....	9
2.1.2 El modelo de nombrado.....	10
2.1.3 El modelo funcional.....	11
2.1.4 El modelo de seguridad.....	11
<u>3 GESTION DE IDENTIDADES Y SINGLE SIGN-ON.....</u>	<u>12</u>
3.1 Gestión federada de identidades.....	15
<u>4 TIPOS DE CONECTIVIDAD. ACCESO REMOTO. VPN.....</u>	<u>18</u>
4.1 Virtual Private Networks (VPN).....	21
4.2 SSL/TLS.....	25
4.3 Secure Shell: SSH.....	26
<u>REFERENCIAS.....</u>	<u>29</u>

1 SEGURIDAD EN ENTORNOS DE RED PRIVADOS. MECANISMOS DE PROTECCIÓN DE LA CONFIDENCIALIDAD

La seguridad es una característica de cualquier sistema, informático o no, que lo protege de todo peligro, daño o riesgo al que pudiera estar expuesto. En el caso de las redes de ordenadores, esta característica es muy difícil de conseguir (incluso podríamos decir que es imposible) por lo que cuando hablamos de seguridad en entornos de red hacemos referencia a la fiabilidad como una medida de la probabilidad de que el sistema se comporte tal y como se espera de él. Nos referimos, por tanto, a todas las medidas hardware y software, personal, documentación, y procesos dentro de la infraestructura de red, que en conjunto protegen la integridad y privacidad de las aplicaciones, datos y flujos de información. El diseño e implementación de una infraestructura de seguridad es una tarea crítica ya que: evoluciona rápidamente, crece en complejidad y tiene especial incidencia en la consecución de los objetivos de la organización.

Hay una serie de aspectos fundamentales que debemos garantizar a la hora de mantener un sistema seguro:

- **Confidencialidad:** Consiste en proteger la información contra la lectura no autorizada explícitamente. Incluye no sólo la protección de la información en su totalidad, sino también las piezas individuales que pueden ser utilizadas para inferir otros elementos de información confidencial.

En un entorno de red, se dispone de dos mecanismos básicos de protección de la confidencialidad:

- o Control de acceso: garantiza la confidencialidad de la información almacenada en un sistema informático al impedir el acceso a la misma por parte de usuarios no autorizados.



- o Técnicas de cifrado: permiten mantener la privacidad de la comunicación entre 2 entidades alterando el mensaje original de modo que sea incomprensible a toda persona distinta del destinatario.
- **Integridad:** Es necesario proteger la información contra la modificación sin el permiso del dueño. La información a ser protegida incluye no sólo la que está almacenada directamente en los sistemas de cómputo sino que también se deben considerar elementos menos obvios como respaldos, documentación, registros de contabilidad del sistema, tránsito en una red, etc. Esto comprende cualquier tipo de modificaciones:
 - o Causadas por errores de hardware y/o software.
 - o Causadas de forma intencional.
 - o Causadas de forma accidental

Cuando se trabaja con una red, se debe comprobar que los datos no fueron modificados durante su transferencia

- **Disponibilidad:** Una buena medida para proteger la información es impedir el acceso a la misma, pero resulta evidente que en ese caso la información dejaría de ser útil. Por tanto, se deben proteger los servicios de cómputo de manera que no se degraden o dejen de estar disponibles a los usuarios de forma no autorizada. La disponibilidad también se entiende como la capacidad de un sistema para recuperarse rápidamente en caso de algún problema.
- **Autenticación:** consiste en la confirmación de la identidad de un usuario; es decir, la garantía para cada una de las partes de que su interlocutor es realmente quien dice ser. Un control de acceso permite garantizar el acceso a recursos únicamente a las personas autorizadas.

- **No repudio:** constituye la garantía de que ninguna de las partes involucradas pueda negar en el futuro una operación realizada.

Para tener una visión global, es de utilidad ver en que capa del modelo de referencia OSI se abordarían cada uno de los aspectos descritos en el apartado anterior. Esto se puede ver en la Tabla 1. Los servicios de la seguridad en la red se expanden sobre las siete capas. Cada tecnología puede trabajar en una o varias capas: Por ejemplo, SSL es una tecnología que trabaja normalmente en la capa de aplicación.

APLICACIÓN	Servicios seguridad Confidencialidad Autenticación Integridad Autorización No repudio	Seguridad lógica	Seguridad proporcionada por fabricante o proveedor
PRESENTACIÓN			Servicio de seguridad proporcionado en la red backbone de transporte
SESION			
TRANSPORTE			
RED			
ENLACE			
FISICO		Seguridad física	

Tabla 1 Seguridad en la red y Modelo de referencia OSI

Una vez identificados los cinco servicios básicos de la seguridad en la red, se pueden examinar las tecnologías que se han definido y desarrollado para implementar esos servicios para necesidades específicas de seguridad y bajo diferentes entornos operativos. Una forma de clasificar estas tecnologías es en base a la manera en que implementan los servicios de seguridad:

- **Tecnologías básicas:** se definen como tecnologías básicas las que sólo implementan un único servicio de seguridad específico. Ejemplos de estas tecnologías son el cifrado, el uso de circuitos permanentes

virtuales (PVCs) en Frame Relay para hacer VPNs de capa 2, o las listas de control de acceso de los routers (ACLs).

- **Tecnologías avanzadas:** este tipo de tecnologías también son diseñadas para implementar un único servicio de seguridad, pero son relativamente más complejas y con frecuencia necesitan del uso de varias tecnologías básicas para conseguir sus objetivos. Un ejemplo es la firma digital para conseguir no repudio en origen.
- **Tecnologías integradas:** este tipo de tecnologías son definidas utilizando otras tecnologías básicas, pero son diseñadas para dar soporte a más de un servicio de seguridad. Ejemplos de estas tecnologías son SSL e IPSEC.
- **Arquitecturas de seguridad:** son tecnologías de arquitectura de seguridad en red, que se definen en base a las tecnologías básicas, avanzadas e integradas. Proporcionan guías para implementar sistemas de seguridad dentro de la arquitectura definida. El mejor ejemplo para esta categoría es el uso de una infraestructura de clave pública (PKI).

2 SERVICIOS DE DIRECTORIO

Un servicio de directorio es una herramienta que almacena y organiza de una manera clara y efectiva la información relativa a los usuarios, aplicaciones, archivos, impresoras y otros recursos accesibles dentro de una red con el objetivo de mejorar la funcionalidad, la facilidad de uso y poder hacer una gestión eficiente de los recursos de la organización.

Un directorio es un listado de información de objetos que están dispuestos en un orden concreto y que aporta información detallada acerca de cada objeto concreto. Ejemplos comunes son la guía de teléfonos de una ciudad o un catálogo de una biblioteca.

Los directorios suelen ser descritos a menudo como una base de datos, pero realmente es una base de datos especializada que tiene unas características propias que los distinguen de las bases de datos relacionales de carácter general:

- Una característica especial es que se accede con mucha frecuencia mediante operaciones de lectura, búsquedas y navegación, mientras que las operaciones de escritura son mucho menos frecuentes.
- Debido a la característica anterior, estos sistemas están diseñados para soportar gran número de solicitudes de lectura y el acceso mediante operaciones de escritura puede estar limitado a ciertos administradores.
- Otra diferencia con las BBDD de propósito general es que la mayoría de implementaciones de los servicios de directorio no son compatibles entre sí.
- Las consultas a las BBDD de propósito general se hacen en base a una herramienta estandarizada de consulta llamada SQL mientras que los directorios suelen utilizar un protocolo de acceso simplificado y optimizado.

Existen numerosas implementaciones de los servicios de directorio de diferentes compañías. Algunos ejemplos son:

- **NIS:** *Network Information Service* es una implementación de Sun Microsystems para redes en el entorno UNIX.
- **Active Directory:** es el servicio de directorio de Microsoft.
- **ApacheDS:** *Apache Directory Studio* es el servidor de directorio de Apache.

- **eDirectory:** es un servicio de directorio desarrollado por Novell que soportado por múltiples plataformas incluyendo Windows, NetWare, Linux.
- **OpenLDAP:** derivado de la implementación original de referencia LDAP de la Universidad de Michigan, pero significativamente evolucionado. Es compatible con prácticamente todas las plataformas actuales: UNIX, Linux, Windows, etc.

Los servicios de directorio formaron parte de una iniciativa del OSI (*Open Systems Interconnection*) para poner de acuerdo a los miembros de la industria en establecer unos estándares de red comunes y así garantizar la interoperabilidad. En la década de los 80 la UIT y la ISO crearon el conjunto de estándares X.500 sobre el modelo de referencia OSI para servicios de directorio. X.500 Consta de los siguientes protocolos: protocolo de acceso al directorio (DAP), protocolo de sistema de directorio, protocolo de ocultación de información y protocolo de gestión de enlaces de directorio.

2.1 LDAP

X.500 es un conjunto de protocolos producido por la *Unión Internacional de Telecomunicaciones*¹ en la década de 1980 que organiza las entradas en el directorio de manera jerárquica, y con una alta capacidad de almacenamiento de datos, proporcionando grandes facilidades de búsqueda y una arquitectura fácilmente escalable. X.500 especifica que la comunicación entre el cliente y el servidor debe emplear el *Directory Access Protocol* (DAP), pero DAP es un protocolo a nivel de aplicación, por lo que tanto el cliente como el servidor debían implementar completamente la pila de protocolos OSI.

¹ ITU por sus siglas en inglés.

LDAP (*Lightweight Directory Access Protocol*) surge como una alternativa a DAP. Se trata de una serie de estándares del *Internet Engineering Task Force*² definidos en varios RFC. La versión más reciente es la v3 y está publicada como el RFC 4510. Las claves del éxito de LDAP en comparación con DAP de X.500 son:

- LDAP utiliza TCP/IP en lugar de los protocolos OSI. TCP/IP requiere menos recursos y está más disponible.
- LDAP representa la información mediante cadenas de caracteres en lugar de complicadas estructuras ASN.1.
- El modelo funcional de LDAP es más simple y ha eliminado opciones raramente utilizadas en X.500, por lo que es más fácil de comprender e implementar.

LDAP define el contenido de los mensajes intercambiados entre un cliente y un servidor LDAP. Los mensajes especifican las operaciones requeridas por el cliente, las respuestas del servidor y los datos transportados en el mensaje. Un ejemplo de interacción general entre un cliente y un servidor LDAP tiene la siguiente forma:

- El cliente establece una sesión con el servidor LDAP. Se conoce como *binding*. El cliente especifica el nombre de host y el puerto dónde escucha el servidor.
- El cliente puede proporcionar un nombre de usuario y contraseña para autenticarse contra el servidor o establecer una sesión anónima con los derechos de acceso por defecto.
- El cliente realiza operaciones sobre los datos del directorio. LDAP ofrece capacidades de lectura y actualización. También posee capacidades de búsqueda de datos en el directorio a través de criterios especificados por el usuario. Las búsquedas son operaciones

² IETF por sus siglas en inglés.

frecuentes en el directorio y se llevan a cabo con ayuda de los filtros de búsquedas.

- Cuando el cliente termina de hacer peticiones, cierra la sesión con el servidor. Esto también se conoce como *unbinding*.

Además de definir el protocolo de acceso al directorio, el estándar LDAP define cuatro modelos que permiten entender mejor el servicio de directorio.

2.1.1 El modelo de información

El modelo de información describe la estructura de la información almacenada en un directorio LDAP. La unidad básica de información almacenada en el directorio es la entrada (entry). Generalmente una entrada representa un objeto del mundo real (una persona, un servidor, etc.), pero el modelo no exige este aspecto.

Una entrada se compone de un conjunto de atributos, cada uno de ellos tiene un tipo y uno o varios valores. El tipo define la clase de información que va a almacenar y los valores son la información en si. Además los atributos tienen un identificador de objeto (OID) y una sintaxis que indica que valores puede contener y como se hacen las comparaciones.

- Ejemplo de atributos: cn: Manuel Rodríguez, ou: VENTAS.

Los esquemas (schemas) definen el tipo de objetos que se van a almacenar en el directorio, también contiene los atributos que tienen estos objetos y si son opcionales u obligatorios.

Dado que cada servidor puede definirse su propio esquema, para permitir la interoperabilidad entre distintos servidores de directorio, se espera que un esquema común sea estandarizado (RFC 2252 y RFC 2256).

2.1.2 El modelo de nombrado

El modelo de nombrado de LDAP define como se organizan y se referencian los datos, es decir, define los tipos de estructuras que se pueden definir utilizando las entradas. Una vez organizadas las entradas formando una determinada estructura, el modelo de nombrado nos indica como referenciar estas entradas.

Las entradas en el directorio describen objetos (una impresora, un usuario, etc.), tienen asociado un identificador llamado *Distinguished Name* (DN) que los identifica unívocamente y se organizan en una estructura de árbol conocida como *Directory Information Tree* (DIT).

A su vez un DN consiste en una secuencia de trozos de información más pequeños conocidos como *Relative Distinguished Name* (RDN). En la estructura de árbol el RDN se correspondería con una rama y el DN se obtendría al seguir todo el árbol desde la raíz a una hoja.

Generalmente el DN se representa mediante una secuencia de RDNs separados por comas. Ejemplo:

- “cn=Pedro Pérez, ou=VENTAS, o=empresa, c=es”.

De este modo, no puede haber ninguna entrada suelta, solo la entrada raíz puede no tener entrada padre. En el caso de añadir una entrada en un punto inexistente en el directorio, el servidor devolverá un mensaje de error y no realizará la operación.

Esta flexibilidad permite que el directorio almacene la información de la forma más conveniente, se puede crear un grupo que contenga todas las personas de la organización y otro que contenga todos los grupos o se puede elegir una estructura que refleje la estructura jerárquica de la organización.

2.1.3 El modelo funcional

El modelo funcional describe que operaciones se pueden llevar a cabo sobre la información almacenada en el directorio LDAP. Estas operaciones se pueden agrupar en tres categorías principales:

- **Autenticación:** *bind*, *unbind* son operaciones utilizadas para conectar y desconectar con el servidor LDAP, establecer derechos de acceso y proteger la información. Se puede securizar una sesión a varios niveles, eligiendo entre una sesión anónima, una sesión autenticada y una sesión autenticada utilizando mecanismos SASL (*Simple Authentication and Security Layer*).
- **Consultas:** es la operación más utilizada. Se pueden hacer búsquedas y comparar información por diversos criterios especificados por el usuario. Las búsquedas se pueden acotar estableciendo un punto de partida en el DIT (*baseDN*), la profundidad a buscar a partir desde el punto de partida (*scope*), los atributos que nos interesan, etc. El elemento clave en las consultas es la definición de filtros de búsqueda (*search Filter*). Los filtros de búsqueda tienen una sintaxis propia que se debe seguir: Ejemplo de filtro: `(|(sn=León)(sn=Castilla))` obtendría las entradas en las que el apellido sea Castilla o León.
- **Actualización:** permite las operaciones de añadir, modificar y borrar las entradas (*add*, *delete*, *modify*).

2.1.4 El modelo de seguridad

El modelo de seguridad describe como la información del directorio puede ser protegida contra accesos no autorizados. El modelo de seguridad se

centra en la operación de *bind*. Hay varias formas de inicio de sesión por parte de un usuario:

- Puede iniciar una sesión de forma anónima con los permisos por defecto.
- Puede iniciar una sesión con un nombre de usuario y contraseña en claro.
- En LDAPv2 solo se permiten sesiones anónimas y autenticación mediante texto en claro, debido a esto algunos fabricantes incorporaron mecanismos de seguridad adicionales, como Kerberos..
- La operación bind de LDAPv3 tiene soporte para Simple Authentication Security Layer (SASL), además se han definido operaciones extendidas, una de ellas relacionada con la seguridad es la Extension for Transport Layer Security (TLS) for LDAPv3.

3 GESTION DE IDENTIDADES Y SINGLE SIGN-ON

Un sistema de gestión de identidades integra políticas y procesos organizacionales destinados a simplificar y controlar el acceso a los sistemas de información y a las instalaciones de una organización por parte de empleados y otras entidades autorizadas. La gestión de identidades persigue la definición de una identidad para cada usuario (persona o proceso), que llevará asociados una serie de atributos.

El concepto central de un sistema de gestión de la identidad es el uso de lo que se conoce como *single sign-on* (SSO). El SSO habilita a un usuario para acceder a todos los recursos de la red después de una única autenticación.

Los principales aspectos que debe cubrir un sistema de gestión de la identidad son los siguientes:

- **Autenticación:** confirmación de que la identidad se corresponde con el nombre de usuario que se proporciona.
- **Autorización:** capacidad de proporcionar permisos para servicios y recursos específicos basándose en la autenticación.
- **Trazabilidad:** proceso que se encarga de registrar accesos y autorizaciones.
- **Aprovisionamiento:** inscripción de usuarios en el sistema
- **Automatización de flujos de trabajo:** movimiento de datos en procesos de negocio.
- **Administración delegada:** el uso de control de accesos basado en roles para proporcionar acceso a recursos.
- **Sincronización de contraseñas:** creación de un proceso para acceder por medio de SSO. *Single sing-on* habilita a un usuario para acceder a todos los recursos del sistema después de una autenticación sencilla.
- **Servicio de reseteo de contraseñas:** capacidad que permite a un usuario cambiar su contraseña.
- **Federación:** proceso por el cual la autenticación y permisos son pasados de un sistema a otro, generalmente a través de diferentes organizaciones, reduciendo así el número de autenticaciones necesarias para el usuario.

En la Figura 1, se pueden ver los elementos que conforman una arquitectura genérica de gestión de la identidad:



- **Principales:** un *principal* es un contenedor de identidad. Típicamente es un usuario que intenta acceder a los servicios y recursos de la red. Dispositivos de usuario, procesos agente y sistemas servidor pueden ser también *principals*. Los *principals* se autentican contra un proveedor de identidad.
- **Proveedor de identidad:** asocia información de autenticación con un *principal*, así como atributos y uno o más identificadores.
- **Servicio de atributos:** las identidades digitales incorporan más atributos que un identificador e información de autenticación. El servicio de atributos gestiona la creación y mantenimiento de estos atributos. Por ejemplo: un usuario que necesita proporcionar una dirección cada vez que entra en una Web de compras. El servicio de gestión de identidad permite proporcionar esta información una sola vez, y será aportada a los consumidores de datos de acuerdo con las políticas de privacidad y autorización establecidas.
- **Consumidores de datos:** son entidades que obtienen y emplean datos gestionados y proporcionados por los proveedores de atributos, y generalmente son utilizados para llevar a cabo decisiones de autorización y auditoria. Por ejemplo un servidor de base de datos es un consumidor de datos que necesita las credenciales del cliente para saber que niveles de acceso debe proporcionarle.

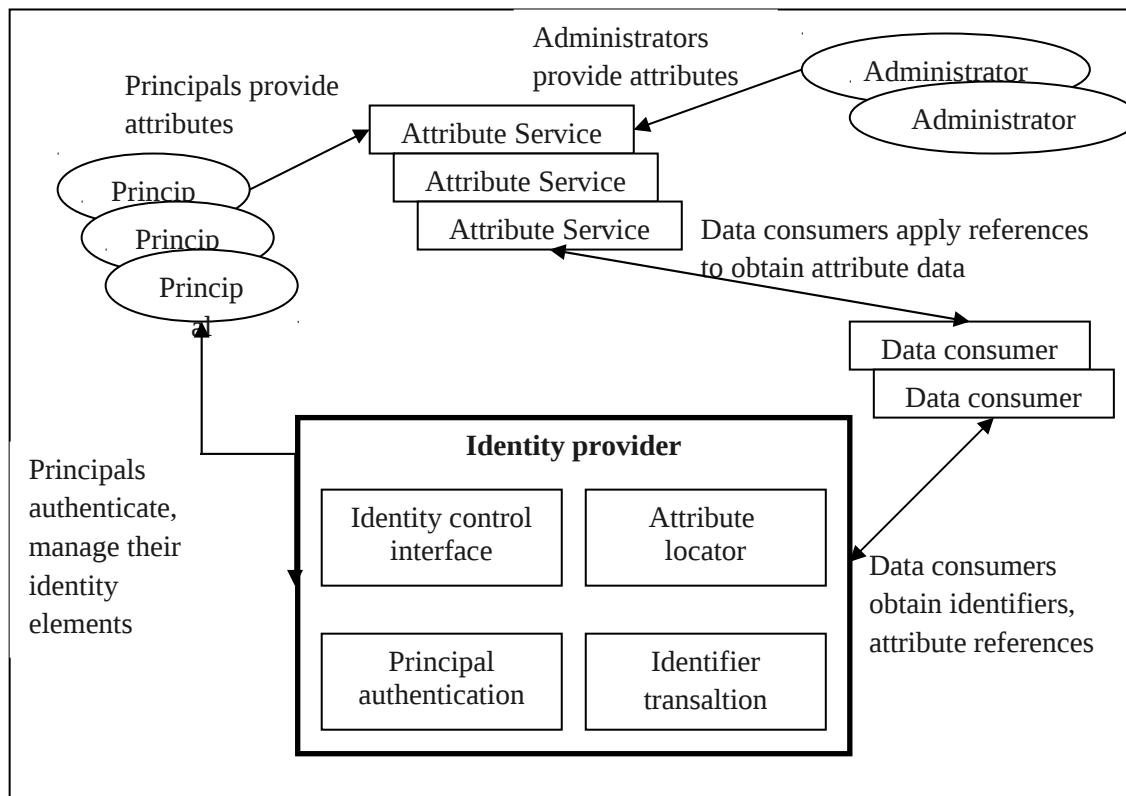


Figura 1: Arquitectura genérica de gestión de la identidad

3.1 Gestión federada de identidades

La federación de identidades es en esencia, la extensión de la gestión de la identidad a múltiples dominios de seguridad. Dichos dominios incluyen unidades internas de negocio, socios de negocio externos y otras aplicaciones y servicios de terceros. El objetivo es proporcionar el intercambio de identidades digitales para que un usuario pueda ser autenticado una sola vez y después pueda acceder a recursos a través de múltiples dominios. Debido a que estos dominios son relativamente autónomos o independientes, no es posible un control centralizado. Sin embargo, las organizaciones colaboradoras deben formar una federación, basada en estándares y niveles de confianza mutua para compartir de forma segura las identidades digitales.

La gestión federada de identidades se refiere a los acuerdos, normas y tecnologías que permiten la portabilidad de las identidades, atributos de identidad, y derechos, a través de múltiples organizaciones y aplicaciones y con la participación de muchos usuarios. Cuando varias organizaciones implementan un esquema de interoperabilidad de identidad federada, un empleado en una organización puede usar un único inicio de sesión, para acceder a servicios a través de la federación mediante relaciones de confianza asociadas a la identidad.

Más allá del SSO, la gestión de identidad federada ofrece otras capacidades: una de ellas es que proporciona un medio estandarizado de representar atributos. Normalmente, las identidades digitales incorporan más atributos que un simple identificador e información de autenticación. Ejemplos de atributos son los números de cuenta, roles en la organización, ubicación física, y propietarios de archivos. Un usuario puede tener múltiples identificadores; por ejemplo, cada identificador puede estar asociado a un único rol, con sus propios permisos de acceso.

La Figura 2 ilustra las entidades y flujos de datos en una arquitectura genérica de gestión federada de la identidad:

1. El navegador del usuario final u otras aplicaciones inician un diálogo con un proveedor de identidad (IdP) en el mismo dominio. El usuario final también proporciona valores de atributos asociados con su identidad.
2. Algunos atributos asociados con la identidad, como por ejemplo roles permitidos, pueden ser proporcionados por un administrador en el mismo dominio.
3. Un proveedor de servicios (SP) en un dominio remoto al que el usuario desea acceder, obtiene el identificador de la identidad, información de autenticación, y atributos asociados desde el proveedor de identidad en el dominio de origen.

4. El proveedor de servicio (SP), abre una sesión con el usuario remoto y refuerza las restricciones de control de acceso basándose en la identidad y atributos del usuario.

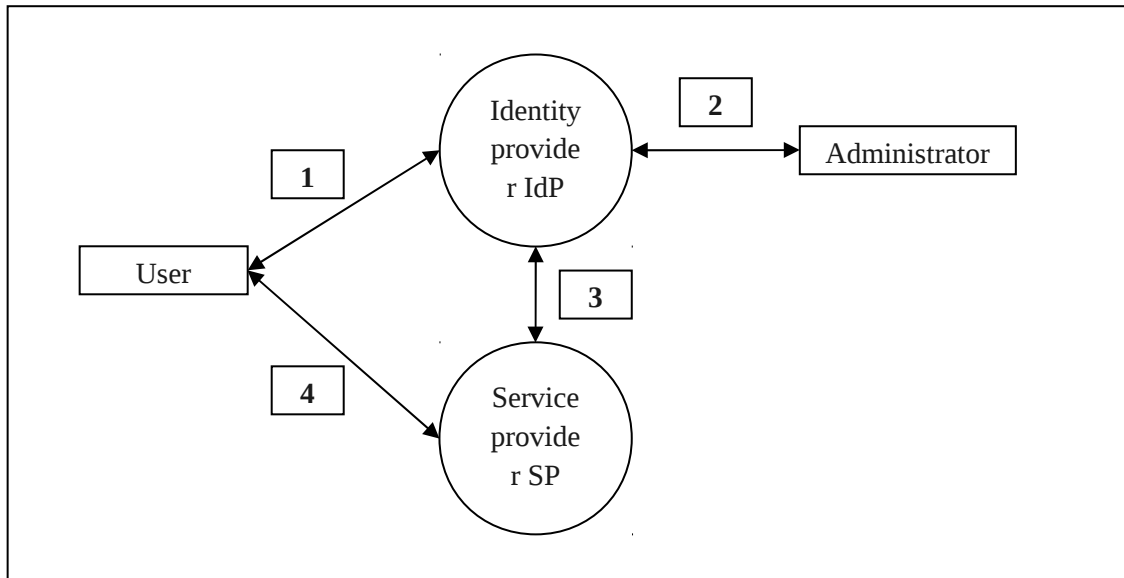


Figura 2: Modo de operación de una federación de identidades

Existe un amplio número de soluciones en el campo de la gestión federada de identidades. Hay estándares abiertos desarrollados por grandes consorcios, soluciones propietarias desarrolladas por compañías privadas y proyectos *opensource* de menor escala. Algunos ejemplos son:

- **SAML:** *Security Assertion Markup Language* es un estándar basado en XML desarrollado por OASIS (*Organisation for the Advancement of Structured Information Standards*). La versión actual es la 2.0 y fue reconocida como estándar en 2005. (<http://www.oasis-open.org/>)
- **OpenID:** es un estándar abierto desarrollado por la *OpenId Foundation*. (<http://openid.net/foundation/>)
- **Shibboleth:** Es un proyecto del consorcio *Internet2*, que proporciona una arquitectura y una implementación *opensource* de un sistema de gestión de la identidad federado basado en SAML. La versión más

reciente de su proveedor de identidad es la 2.3.0 y data de 2011.
(<http://shibboleth.internet2.edu/>)

- **WS-Federation:** Es un Framework desarrollado por varios fabricantes entre los que destacan IBM y Microsoft. Su especificación mas reciente es la 1.1 y data de 2006.
(<http://www.ibm.com/developerworks/library/specification/ws-fed/>)
- **Liberty Identity Federation Framework (ID-FF):** Es un Framework de gestión federada de la identidad, desarrollado por un consorcio formado por más de 150 empresas y organizaciones y conocida con el nombre de Liberty Alliance.

4 TIPOS DE CONECTIVIDAD. ACCESO REMOTO. VPN.

El acceso remoto es la capacidad de un usuario de obtener acceso a un servidor o a una red desde una localización remota. Personal en delegaciones de la organización, teletrabajadores o personal que está viajando pueden necesitar acceder a la red corporativa. Hay varias formas de conectar el equipo o red remota con la red corporativa:

- Los usuarios que trabajan desde casa consiguen acceso a Internet a través de un proveedor de servicios de Internet (ISP). Una forma de conectarse es por medio de conexiones desde un portátil o equipo de sobremesa con ayuda de líneas DSL y cable módem con ayuda de VPNs.
- Otra alternativa basada en el uso de VPN es la que pueden utilizar los usuarios que están viajando y no disponen de una conexión cableada. Para ello se pueden valer de conexiones inalámbricas (Wifi, Wimax) proporcionadas por dispositivos móviles preparados

para gestionar este tipo de conexiones. También pueden acceder con ayuda de conexiones de datos de telefonía móvil.

- El uso de un enlace privado, entre una red remota y la red corporativa es una opción útil para por ejemplo conectar la sede de una organización con sus delegaciones. Los enlaces privados suelen ser más caros, pero ofrecen mayor fiabilidad y ratios de transferencia más elevados. Ejemplos de tecnologías que proporcionan enlaces privados son ATM, Frame Relay, Clear Channel, RDSI, Fibra óptica.
- La utilización de radio enlaces de larga distancia o conexiones vía satélite es otra forma de comunicar una red remota con la red de la organización.

Para acceder remotamente de una forma segura a la red de la organización, son necesarias algunas capacidades básicas relacionadas con la seguridad en los sistemas de acceso remoto:

- **Control de acceso a la red:** la primera línea de defensa, en la seguridad de acceso remoto, es el control de acceso para prevenir que accedan los intrusos no deseados. Para ello se define una política de seguridad que describe como se puede acceder de forma segura a la red. Ejemplos de esto son los portales cautivos, el uso del protocolo 802.1X, etc.
- **Autenticación de usuarios y autorización:** es la segunda línea de defensa y asegura que la autenticidad de un usuario mediante el uso de protocolos de autenticación.
- **Protección de la conexión e integridad del tráfico:** una vez que se establece una sesión, es necesario asegurar la confidencialidad e integridad del tráfico intercambiado entre las partes.

No hay estándares formales definidos específicamente para explicar como debe ser una arquitectura de acceso remoto, porque cada organización tiene sus características y requisitos de acceso remoto. Sin embargo, hay componentes funcionales que se convierten en estándares de facto en un despliegue típico de acceso remoto. Los componentes clave que deberían ser tenidos en cuenta en una arquitectura de acceso remoto típica son los siguientes:

- **Firewall:** es un conjunto de tecnologías hardware y software instaladas estratégicamente entre las redes privadas de la compañía y una o más redes no seguras (incluida Internet).
- **Zona desmilitarizada (DMZ):** es un elemento común en la mayoría de despliegues de cortafuegos. Es utilizada para proporcionar una zona diferenciada entre los equipos de la red privada que no tienen acceso desde el exterior y los servidores que si tienen conexión exterior. En esta red hay servidores bastión que actúan como intermediarios entre los accesos remotos y la organización. Ejemplos de este tipo de servidores son los proxies y los servidores de autenticación.
- **Servidor de acceso remoto (RAS):** es un servidor que actúa de puerta de enlace entre el cliente remoto y la red, en arquitecturas de conexión mediante enlaces conmutados analógicos y/o digitales (p.ej: RDSI). Una vez que un usuario remoto establece la conexión por medio de una llamada, la línea telefónica es transparente para el usuario, y puede acceder a los recursos de la red interna.
- **Servidor Proxy:** es un servidor, que actúa como intermediario entre un usuario remoto y las aplicaciones y servicios internos de la organización a los que desea acceder. De esta manera la empresa puede garantizar la seguridad de las aplicaciones internas, el control administrativo y tener capacidades de caché (por ejemplo en accesos

vía Web). La autenticación del usuario puede ser hecha por el propio Servidor Proxy o por un servidor de autenticación.

- **Servidor de autenticación:** es el encargado de verificar la identidad de los usuarios que intentan acceder a la red privada de la organización.

4.1 Virtual Private Networks (VPN)

Las redes privadas virtuales (VPN), proporcionan una forma segura de conectarse desde una ubicación remota con una red de área local privada (LAN) a través de Internet o cualquier otra red pública no segura. Una VPN es una conexión que tiene la apariencia y muchas de las ventajas de un enlace dedicado pero trabajando sobre una red pública. Para esto se utiliza una técnica llamada *tunneling* que permite enrutar los paquetes de datos por la red pública en un túnel privado que simula una conexión punto a punto. Las VPN son utilizadas frecuentemente por los trabajadores remotos o empleados en las delegaciones de la organización, para compartir datos y recursos de la red privada. Una red privada virtual puede proporcionar los siguientes beneficios para la organización:

1. **Seguridad mejorada:** al reducir el número de conexiones con el mundo exterior se reduce considerablemente la posibilidad de un ataque. Además también se reduce la posibilidad de interceptación del tráfico.
2. **Rendimiento predecible:** en VPNs con canales dedicados se puede garantizar el ancho de banda entre los sitios y el rendimiento de la red se hace más predecible.
3. **Independencia en la elección de las tecnologías de transporte para las redes de usuarios:** las posibilidades están limitadas por la elección de un proveedor o fabricante. Así la organización puede usar

Ethernet, Frame Relay, IP y otras tecnologías de red para conectar sus sitios.

- 4. Espacio de direcciones IP independiente:** en las redes privadas es posible utilizar cualquier direccionamiento. Por ejemplo, casi todos los servicios de VPN permiten el uso de direcciones IP privadas tales como 10.0.0.1 o 192.168.0.3, que no pueden ser enrutadas a través de las redes públicas.

Estas características serán de utilidad para algunos usuarios, pero de importancia relativa para otros. Las vulnerabilidades y bajo rendimiento de las redes públicas pueden hacer que la “seguridad mejorada” y “rendimiento predecible” sean las características más deseables de una VPN. Recientemente, la “independencia de elección de tecnología” y el “espacio de direcciones independiente” parece que se han vuelto menos importantes: el primero debido a la dominación de las tecnologías Ethernet en capa 2 e IP en capa 3. La segunda debido a que con la implantación de IPv6 se espera acabar con el déficit de direcciones. De todas formas, tener un espacio de direcciones independiente mejora la seguridad, utilizando rangos de direcciones para separar sitios dentro de la organización y restringir accesos.

A la hora de crear una VPN para proporcionar acceso remoto, hay que escoger la tecnología que mejor se adapte al escenario en cuestión. Esta elección de tecnología implica técnicas de *tunneling*, autenticación, control de acceso y seguridad de datos. Generalmente se definen tres arquitecturas principales de VPN:

- **Intranet VPN (LAN-to-LAN VPN):** en este escenario las redes remotas de la organización son conectadas entre sí utilizando la red pública, convirtiéndose de esta manera en una única red LAN corporativa global.

- **VPN de acceso remoto:** en este tipo de VPNs se ubicarían los usuarios que desde un host remoto crean un túnel para conectarse a la red privada de la organización. El dispositivo remoto puede ser un equipo personal con un software cliente para crear VPN, y usar una conexión conmutada o una conexión de banda ancha permanente.
- **Extranet VPN:** este tipo de arquitecturas permiten que ciertos recursos de la red privada de la organización sean accedidos por redes de otras compañías, tales como clientes o proveedores. En este escenario es fundamental el control de acceso.

Hay una amplia variedad de tecnologías que se pueden utilizar para la implementación de VPNs. Los criterios que deben cumplir estas tecnologías son:

- **Seguridad:** las conexiones deben ser brindadas cumpliendo con los requisitos de autenticación, autorización, privacidad, integridad y contabilidad.
- **Eficiencia:** los tiempos de respuesta deben ser adecuados y comparables con las redes consideradas “no seguras.”
- **Facilidad de administración:** los usuarios y administradores de este tipo de redes, pueden hacer su trabajo de una manera rápida y efectiva.
- **Cumplimiento de estándares e interoperabilidad:** hay muchas tecnologías que son estándares y que participan en la creación de VPNs: IPSec, MD5, SOCKSv5, IKE, ISAKMP, Diffie-Hellman, X.509, RADIUS, etc.

Para clasificar las tecnologías que se pueden utilizar en la implementación de una arquitectura de VPN, se puede tomar como referencia el modelo OSI y ubicarlas en función del nivel en el que son implementadas. La Figura 3

muestra los principales protocolos utilizados para el establecimiento de conexiones VPN y su ubicación en el modelo de referencia OSI.

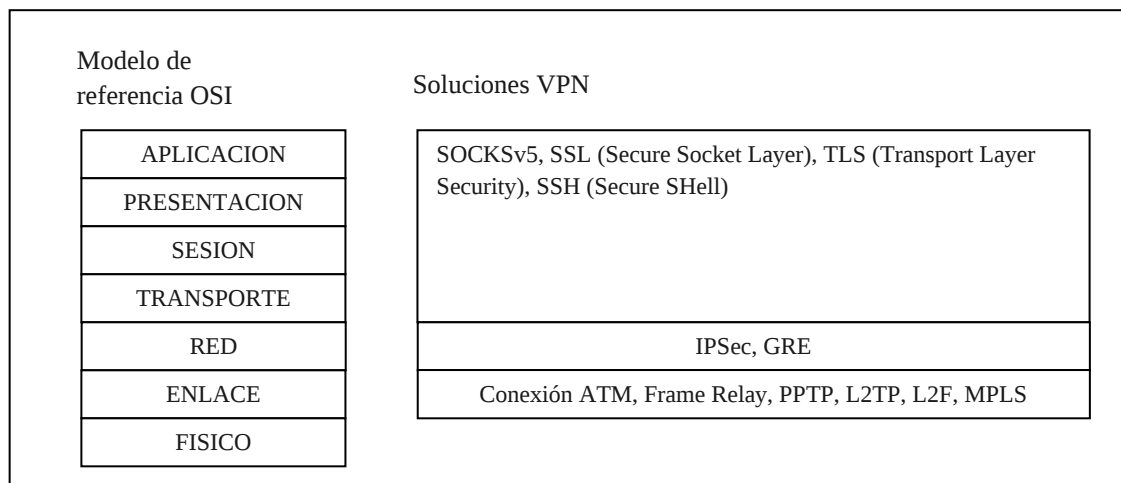


Figura 3: Ubicación de las soluciones VPN en el modelo de referencia OSI

A la hora de implementar una arquitectura de red basada en VPN hay dos posibles opciones. Hacer una implementación por hardware o por software.

Las implementaciones por Hardware realizan el proceso de encriptación y desencriptación del tráfico a nivel físico entre los extremos de la línea de comunicación. Los dispositivos utilizados normalmente son routers con capacidades de VPN incorporadas. Como ventajas de esta solución se puede decir que la instalación y configuración son relativamente sencillas, no se necesita personal especializado y su mantenimiento es mínimo. Por el contrario presentan el inconveniente de que el sistema de encriptación viene impuesto por el fabricante y se depende del mismo para las actualizaciones.

Por otro lado las implementaciones basadas Software se están imponiendo cada día más. La explicación radica en que, la necesidad de los usuarios pequeños y medianos de implantar sistemas de seguridad en el acceso a sus máquinas va en aumento. Las implementaciones software son mucho

más baratas que comprar hardware preparado para VPNs y existe un gran número de VPNs desarrolladas por software. Como inconvenientes de esta aproximación se puede decir que es necesaria una máquina para dar soporte a la solución, el sistema de claves y certificados reside en máquinas potencialmente inseguras y en los casos que se utilice software de libre distribución puede ser que tenga puertas traseras u otras deficiencias de seguridad.

4.2 SSL/TLS

SSL/TLS son los acrónimos de *Secure Sockets Layer/Transport Layer Security*. El protocolo SSL es desarrollado en 1995 por Netscape. Se basa en una arquitectura cliente/servidor y fue diseñado originalmente para permitir el intercambio de información seguro entre un servidor Web y un navegador. Hoy en día el IETF mantiene el desarrollo de TLS como un protocolo estándar de Internet. La versión más reciente TLS 1.2 está definida en el RFC 5246 y fue publicada en 2008.

SSL es un protocolo que proporciona autenticación y confidencialidad entre los extremos de la comunicación mediante el uso de criptografía. Cuando se establece una comunicación por SSL, habitualmente sólo el servidor es autenticado, aunque es posible la identificación mutua mediante el despliegue de una infraestructura de claves públicas (PKI). SSL implica una serie de fases básicas:

- Negociar entre las partes el algoritmo que se empleará en la comunicación.
- Intercambio de claves públicas y autenticación basada en claves públicas.
- Encriptación del tráfico por medio del uso de cifrado simétrico.

Durante la primera fase, se negocian los algoritmos criptográficos que se van a usar entre el cliente y el servidor:

- Protocolos de clave pública: RSA, DSA, Diffie-Hellman, etc.
- Protocolos de cifrado simétrico: DES, 3DES, IDEA, AES, RC2, etc.
- Funciones resumen: MD5 o familia SHA.

SSL/TLS proporcionan un abanico amplio de medidas de seguridad:

- Se numeran todos los registros usando el número de secuencia en el MAC (*Message Authentication Code*).
- Se usa un resumen de mensaje mejorado con una clave (sólo se puede comprobar el MAC con dicha clave).
- Proporcionan protección contra varios ataques conocidos (por ejemplo: *man-in-the-middle-attack*).
- Al finalizar la conexión se envía en el mensaje un hash de todos los datos intercambiados y vistos por ambas partes.

SSL se ejecuta en una capa entre los protocolos de aplicación como HTTP, SMTP, NNTP y sobre la capa de transporte TCP del protocolo TCP/IP. Aunque puede proporcionar seguridad a cualquier protocolo que utilice conexiones de confianza (tal como TCP), se usa en la mayoría de los casos junto a HTTP para formar HTTPS. Otra aplicación en la que se puede utilizar SSL es en el *tunneling* de una red completa y poder crear así una VPN, como se hace por ejemplo con *OpenVPN*.

4.3 Secure Shell: SSH

Secure Shell o SSH es un protocolo de red que permite el intercambio de datos entre dos dispositivos conectados a la red utilizando un canal seguro.

Las dos principales versiones del protocolo son conocidas como SSH1 y SSH2. Se usa principalmente en entornos UNIX y Linux para acceder a consolas remotas. Fue creado en el año 1995 por el investigador de la Universidad de Helsinki Tatu Ylönen y su principal objetivo era proporcionar una alternativa segura para Telnet y otros intérpretes de comandos remotos. En el año 2006 se convierte en un estándar del IETF descrito en el RFC 4253. La definición de su arquitectura incluye tres protocolos apilados en las capas de transporte y aplicación:

- *SSH Connection Protocol*: en este protocolo se define el concepto de canales, peticiones de canal y peticiones globales que los servicios SSH proporcionan.
- *SSH User Authentication Protocol*: en este protocolo se maneja la autenticación de clientes y se proporcionan varios métodos de autenticación. Algunos de los métodos utilizados son: el uso de contraseñas ordinarias, autenticación de clave pública basada en DSA, RSA y certificados X.509, Kerberos, etc.
- *SSH Transport Layer Protocol*: este protocolo maneja el intercambio inicial de claves, así como la autenticación del servidor, el establecimiento del tipo de cifrado, compresión y verificación de integridad.

El uso de SSH se extendió y puede ser utilizado por un amplio número de aplicaciones sobre múltiples plataformas incluidas UNIX, Windows, MAC OS y Linux:

- Transferencia segura de ficheros utilizando las aplicaciones SCP y SFTP.
- Sistemas de ficheros en red: SSHFS. Es una alternativa a NFS, en la que el cliente no necesita que el servidor exporte un directorio por NFS, le basta tener acceso por SSH.



- *Port forwarding*: Permite una comunicación segura sobre red una insegura, muy similar a una VPN, pero trabajando con un único puerto.
- *OpenSSH* desde la versión 4.3 permite hacer verdaderas VPN (todos los puertos), tanto en nivel de enlace como nivel de red.

En el mercado existen diversas implementaciones:

- *ssh* original con licencia freeware.
- *OpenSSH*, desarrollada originalmente para OpenBSD, portada a muchos otros SO, es la versión más empleada.
- *Dropbear*, es una versión reducida, habitual en sistemas empuotrados como OpenWRT.
- En Microsoft Windows se puede utilizar el servidor *CopSSH* y el cliente *Putty*.

REFERENCIAS

- **FUNG, K. T.** (2005). Network security Technologies. Second Edition. AUERBACH PUBLICATIONS.
- **STALLINGS, W.** (2011). Network Security Essentials. Applications and Standards. Fourth Edition. Prentice Hall.
- Curso de Extensión Universitaria "Ferramentas de seguridade en GNU/Linux" (terceira edición) - Escola Superior de Enxeñaría Informática da Universidade de Vigo - (<http://ccia.ei.uvigo.es/curso2010/index.html>)
- Apuntes de la asignatura Diseño y Administración de Sistemas y Redes – Ingeniería Informática – Universidad Rey Juan Carlos.
(http://gsyc.escet.urjc.es/~mortuno/index_dasr.html).

(Todos los enlaces fueron verificados en Junio de 2011)

Autor: Juan Otero Pombo
Ingeniero en Informática en el Concello de Ourense
Colegiado del CPEIG